

7.4A Scenario-based Risk Assessment

Control Type: Advisory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
Control Definition Control Objective: Evaluate the risk and readiness of the organisation based on plausible cyber-attack scenarios. In-scope components: - Organisational control (people, processes, and infrastructure) to be also met by a third party operating a remote virtualisation or cloud platform that hosts Swift-related VMs. Risk Drivers: - excess harm from deficient cyber readiness - unidentified sensitivity to cyber exposure						
Implementation Guidance Control Statement: Scenario-based risk assessments are conducted regularly to improve incident response preparedness and to increase the maturity of the organisation's security programme. Control Context: Scenario-based risk assessments include cyber wargames, test attacks on existing systems and processes targeting the user's Swift infrastructure. Scenario-based risk assessments also include technical and business driven exercises performed as part of an institution risk management or Information Security Risk Management (ISRM) process. These assessments include the following threats: end-user impersonation, message tampering, message eavesdropping, third-party software weaknesses, compromising systems or Denial of Service (DoS) attacks affecting service availability. Results of the assessment and existing mitigations help identify areas of risks that may require future actions, risk mitigations or an update of the cyber incident response plan. Identified resulting actions, mitigations, or updates must be reported and closed in line with their criticality as per the internal or organisation's Information Security Risk Management (ISRM) process. Several ISRM frameworks exist and can be consulted⁴⁰ to define the user's proper ISRM and resources (such as CIS-Critical Security Controls). These frameworks can be used to start implementing a basic risk management process to be further enhanced to address user's specific risks. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). - A scenario-based risk assessment and planning activity is conducted to: - identify possible methods for adversaries to gain unauthorised access to the user's Swift infrastructure based on observed adversary techniques or plausible adversary techniques inferred from adversaries' motivations and capabilities - analyse the effectiveness of existing prevention and detection controls to mitigate anticipated adversary techniques to gain unauthorised access to the environment						

⁴⁰ For example, on NIST, ENISA, COBRA or ISO sites or from a local or regulator's standard or controls set to the same level of rigour as industry guidance.

- analyse the probability and impact of significant and plausible attack vectors given existing controls
- analyse the effectiveness of existing response controls to limit impact of significant and plausible attack vectors given existing controls
- Identify the need for additional preventive or detective controls

All those activities can be covered through the organisation's ISRM.

- Assessment and planning activity is conducted at least annually, and updated through ongoing risk management activities, when significant technology changes occur, or when threat intelligence indicates relevant changes in an applicable adversary's capabilities or motivations.
- Current threat intelligence and observed or likely attacks (vectors, techniques, actors,) are used as the basis for scenarios.
- Each asset class (end-user devices, servers, network devices) is assessed against threats on a regular basis and when changes are introduced or when new threats are identified.

Appendix A: Risk Driver Summary Matrix

The matrix below is a summary of the risk drivers in this document, mapping the security controls to the documented risks they are intended to help mitigate.

Swift Security Controls	1.1	1.2	1.3	1.4	1.5	2.1	2.2	2.3	2.4	2.5A	2.6	2.7	2.8	2.9	2.10	2.11A	3.1	4.1	4.2	5.1	5.2	5.3A	5.4	6.1	6.2	6.3	6.4	6.5A	7.1	7.2	7.3A	7.4A
Risk Drivers																																
Authentication token theft																					X											
Business conducted with an unauthorised counterparty																X																
Compromise of enterprise authentication system	X				X																											
Compromise of trusted back-up data										X																						
Compromise of user credentials	X				X																											
Credential replay	X				X														X													
Deletion of logs and forensic evidence		X																														
Excess attack surface								X							X																	
Excess harm from deficient cyber readiness															X														X			X
Excess privilege or access		X																		X												
Execution of malicious code																								X								
Exploitation of insecure system configuration								X							X									X								

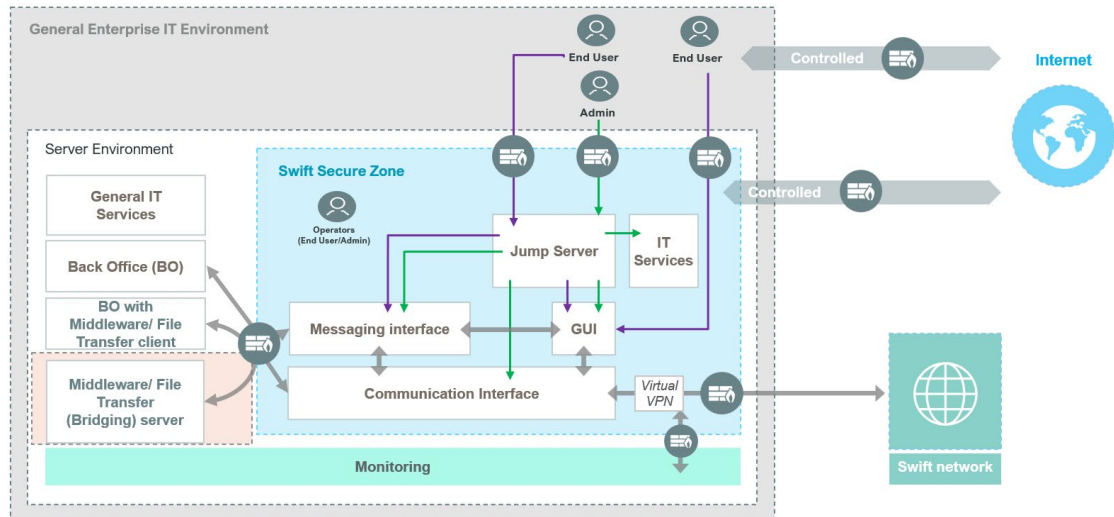
Swift Security Controls	1.1	1.2	1.3	1.4	1.5	2.1	2.2	2.3	2.4	2.5A	2.6	2.7	2.8	2.9	2.10	2.11A	3.1	4.1	4.2	5.1	5.2	5.3A	5.4	6.1	6.2	6.3	6.4	6.5A	7.1	7.2	7.3A	7.4A
Risk Drivers																																
Exploitation of known security vulnerabilities							X					X												X								
Exposure to internet-based attacks	X			X	X																											
Exposure to sub-standard security practices													X																			
HSM management misused		X																		X	X				X							
Increased security risk from improperly trained staff																														X		
Lack of traceability		X															X				X						X					
Loss of operational confidentiality											X																					
Loss of operational integrity											X																					
Loss of sensitive data confidentiality						X			X	X																						
Loss of sensitive data integrity						X			X																	X						
Password cracking, guessing, or other computational compromise																		X	X													
Password theft											X								X				X									
Separation of duty violations																				X												
Unauthorised access	X		X		X	X			X											X												
Unauthorised physical access																	X															

Swift Security Controls	Risk Drivers																															
	1.1	1.2	1.3	1.4	1.5	2.1	2.2	2.3	2.4	2.5A	2.6	2.7	2.8	2.9	2.10	2.11A	3.1	4.1	4.2	5.1	5.2	5.3A	5.4	6.1	6.2	6.3	6.4	6.5A	7.1	7.2	7.3A	7.4A
Unauthorised system changes		X																							X							
Unauthenticated system traffic						X			X																							
Uncontrolled proliferation of systems and data			X																													
Undetected anomalies or suspicious activity														X													X	X				
Unidentified sensitivity to cyber exposure																																X
Unknown security vulnerabilities or security misconfigurations												X																		X		
Untrustworthy staff or system operators																						X										

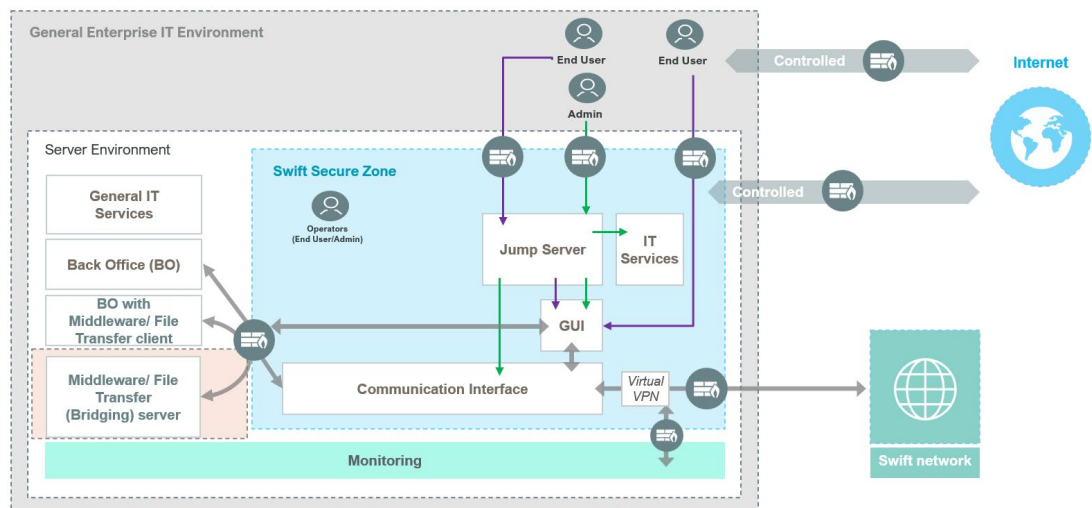
Appendix B: Secure Zone Reference Architectures

The following diagrams are for reference only, and describe one of many ways for the secure zones to be designed for each architecture (A1, A2, A3, A4, B); the CSP architecture [decision tree](#) can be used to identify the architecture type that matches best, and the [Outsourcing Agents Security Requirements Baseline](#) that describes specific cases when components are outsourced.

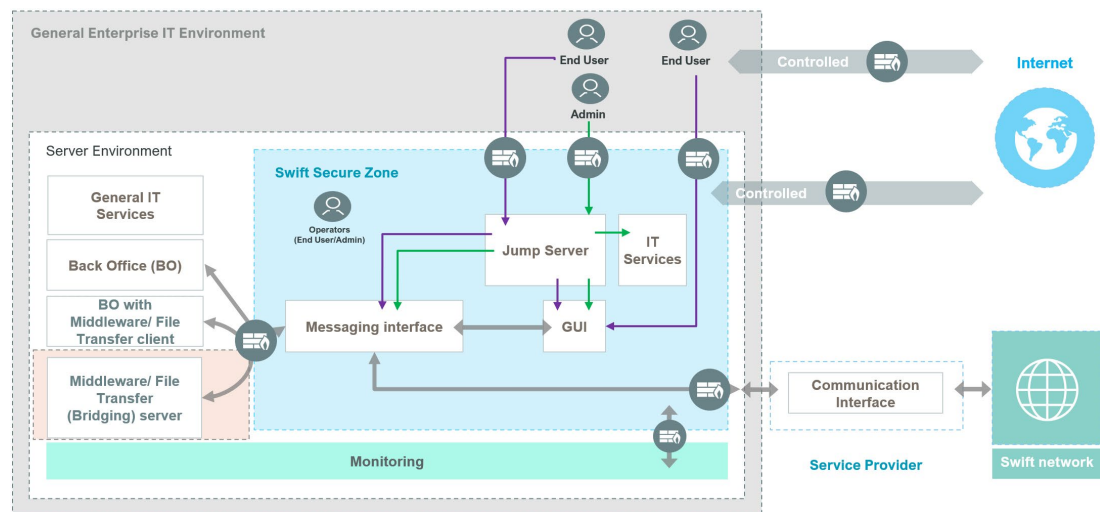
Drawing 11a: Secure Zones Example for Architecture A1
Interfaces within the user environment (on premises or in the cloud)



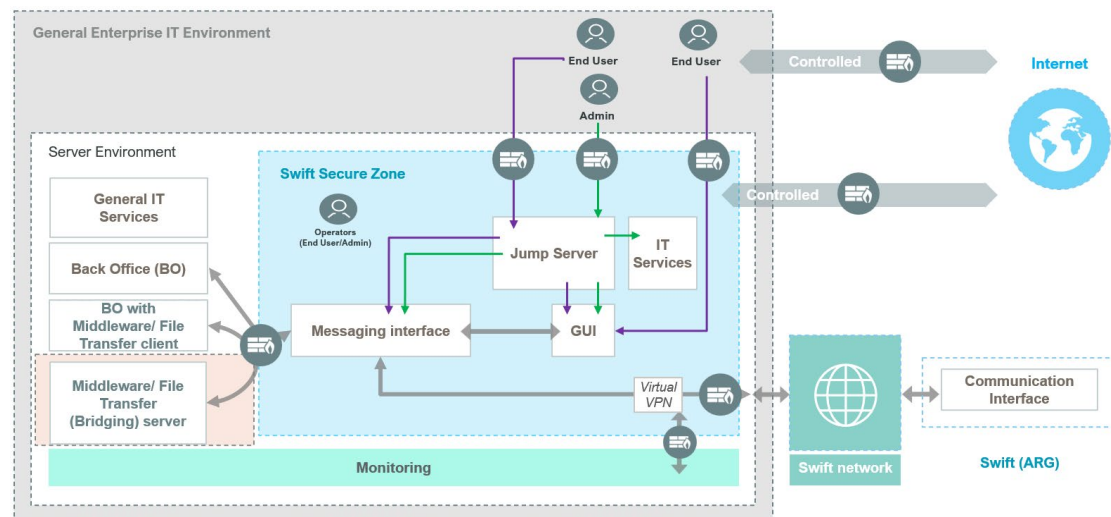
Drawing 11b: Secure Zones Example for Architecture A1
Communication interface only within the user environment (on premises or in the cloud)



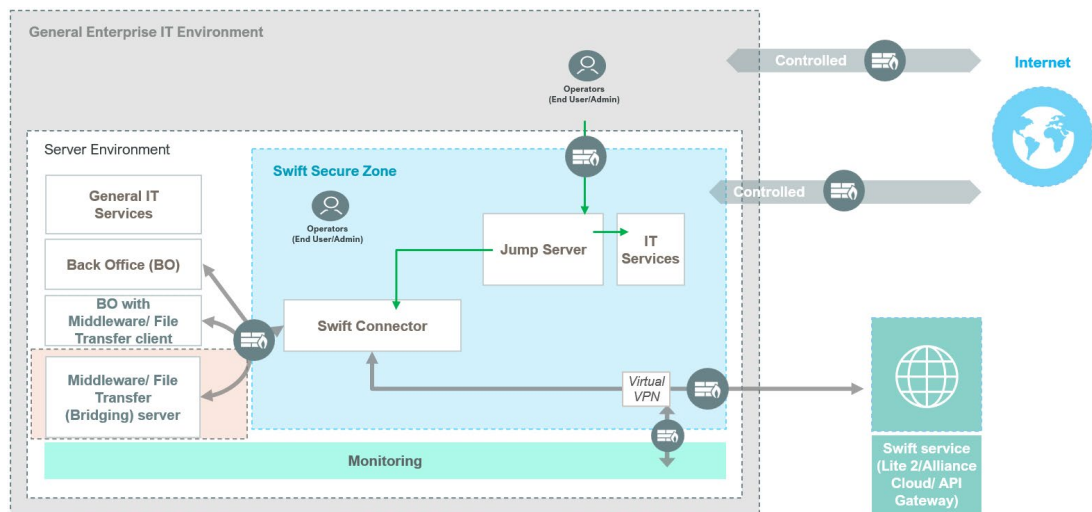
Drawing 12a: Secure Zone Example for Architecture A2
Messaging interface only within the user environment (on premises or in the cloud) towards a Service Provider (not Swift)



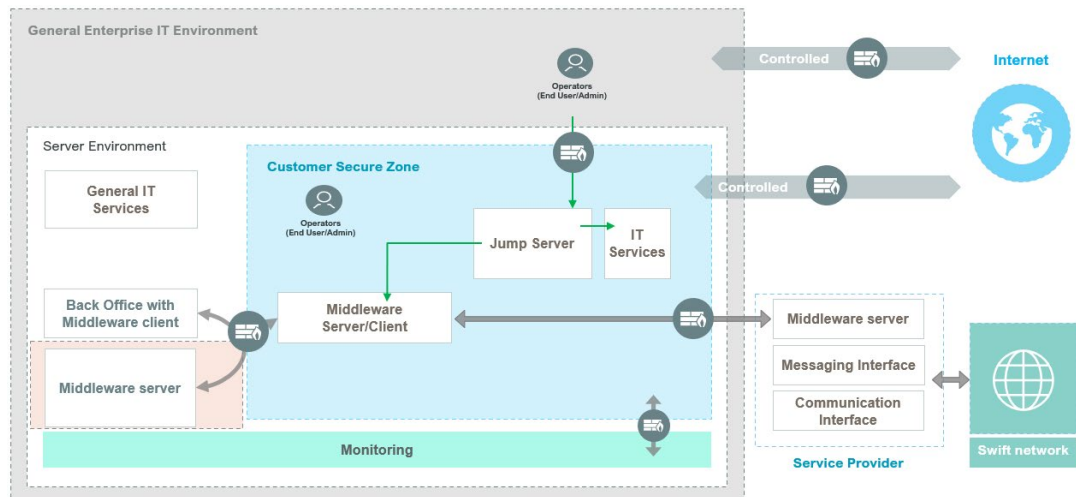
Drawing 12b: Secure Zone Example for Architecture A2
Messaging interface only within the user environment (on premises or in the cloud) towards Swift ARG service



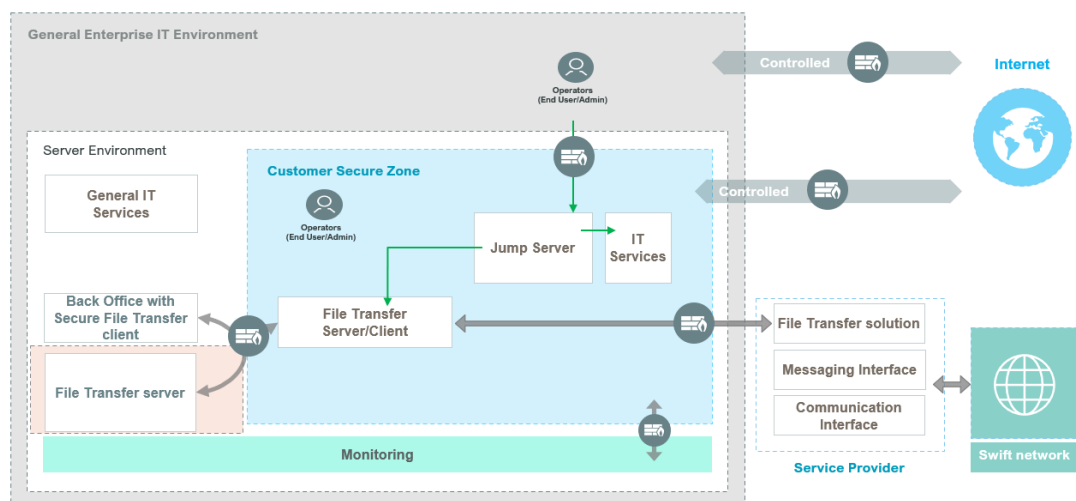
**Drawing 13a: Secure Zone Example for Architecture A3
Swift connector**



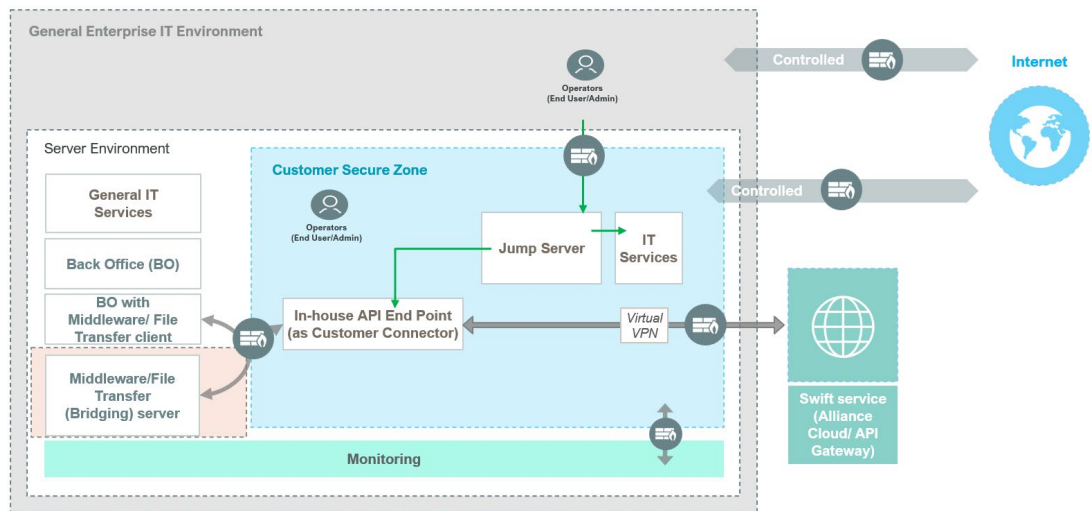
**Drawing 13b: Secure Zone Example for Architecture A4
Middleware server/client as Customer Connector**



**Drawing 13c: Secure Zone Example for Architecture A4
File Transfer server/client as Customer Connector**



Drawing 13d: Secure Zone Example for Architecture A4
In-house customer API End Point as Customer Connector



Appendix C: Sample Threat Scenarios

The following scenarios are examples to help users to understand the types of cyber-threats that each security control is intended to help mitigate. These scenarios are non-exhaustive and provided for context and educational purposes only. The likelihood and impact of each scenario may differ significantly based on variables within the user environment.

1.1 Swift Environment Protection

- Attackers compromise credentials of the system administrator of the enterprise Active Directory, thereby granting the attackers access to all login credentials stored in the directory.
- Attackers compromise supporting IT infrastructure (for example, scanning server, patching server), located in the general IT environment. The objective is to steal system credentials and subsequently access the user's Swift infrastructure.
- Attackers gain administrative access to an operator's PC, allowing the attacker to compromise the local account database and reuse the stored hashes to access other systems.

1.2 Operating System Privileged Account Control

- A system administrator using the root account in Linux performs unauthorised actions (for example, changing security configurations, causing an intentional system crash), which are not traceable to an individual operator.
- An operator with excess administrative privileges deletes logs and other forensic evidence to hide unauthorised actions.

1.3 Virtualisation or Cloud Platform Protection

- An attacker with access to the hypervisor or the cloud platform could compromise the confidentiality, integrity and availability of virtual machines hosting Swift services.
- An attacker with access to the hypervisor or the cloud platform provisioning function could create new virtual machines to support the attack. For example, they can create fake application services to cause users to divulge sensitive information or download malware.
- An attacker benefits of vulnerabilities or insecure configuration of the hypervisor or the cloud platform to breach separation between hosted virtual machine domains to access virtual machines hosting Swift services.

1.4 Restriction of Internet Access

- Attackers compromise supporting IT infrastructure (for example, middleware server or virtualisation platform server), to steal system credentials and subsequently access the user's Swift infrastructure.
- Attackers gain administrative access to an operator's PC, allowing the attacker to compromise the local account database and reuse the stored hashes to access other systems.
- An operator clicks a malicious link in an e-mail or web page, unknowingly downloading malware which compromises the operator's PC or server.

1.5 Customer Environment Protection

- Attackers compromise credentials of the system administrator of the enterprise Active Directory, thereby granting the attackers access to all login credentials stored in the directory.
- Attackers compromise supporting IT infrastructure (for example, scanning server, patching server), located in the general IT environment. The objective is to steal system credentials and subsequently access the customer infrastructure.
- Attackers gain administrative access to an operator's PC, allowing the attacker to compromise the local account database and reuse the stored hashes to access other systems.

2.1 Internal Data Flow Security

- An attacker with network access to the secure zone compromises the integrity of the transactions in transit between the messaging interface and communication interface.
- An attacker with network access to the secure zone is able to monitor unencrypted traffic between user's Swift components and record confidential transactions.

2.2 Security Updates

- An attacker uses a known and unpatched vulnerability to gain access to a server hosting a Swift-related component.
- The operating system has aged beyond the vendor's support life-cycle window, resulting in persistent open vulnerabilities with no available remediation from the vendor.

2.3 System Hardening

- An attacker uses the default username and password to access the administration interface of a network firewall.
- An attacker uses a vulnerability associated with an unused network protocol (for example, telnet) to gain access to a Swift server.

2.4 Back Office Data Flow Security

- An attacker positioned on the used middleware server or between the back office and messaging interface injects unauthenticated transactions.
- An attacker creates a "person-in-the-middle" attack to change the beneficiary accounts of valid transactions.
- An attacker positioned on the used middleware server or between the back office and messaging interface can monitor unencrypted traffic and record confidential transactions.

2.5A External Transmission Data Protection

- A data back-up location is compromised, and unencrypted Swift back-ups and credential hashes are accessed, providing the attacker with valuable information about Swift operators and typical activity within the user's environment.
- Unencrypted back-ups of Swift servers are transmitted over an insecure network connection, resulting in an attacker gaining read-access to all recent messaging traffic records.

2.6 Operator Session Confidentiality and Integrity

- An operator leaves the desk and no timed screen lock-out is implemented, allowing an unauthorised person access to the operator's account and the Swift messaging interface.
- An attacker is able to perform surveillance on an unencrypted operator session (for example through telnet), and learns from unencrypted information to plan a future attack.
- An attacker is able to perform surveillance on an unencrypted operator session (for example through telnet), and steals credentials to create a fraudulent transaction.
- An attacker intercepts a transaction sent between the browser and the web application, modifies the transaction content, and forwards it to the web application.
- An attacker is able to hijack an open session or bypass an authentication scheme due to unsafe settings to capture or create fraudulent transactions.

2.7 Vulnerability Scanning

- A discoverable vulnerability is left unidentified and untreated, allowing an attacker to exploit the vulnerability to gain access to a Swift-related system.

2.8 Outsourced Critical Activity Protection

- An outsourced provider does not properly separate Swift systems from other low-security systems, resulting in a virus spreading across environments and affecting the integrity of the Swift systems.
- An outsourced provider does not properly enforce access control, resulting in an unauthorised employee gaining access to the Swift messaging interface or other Swift-related components or systems.

2.9 Transaction Business Controls

- Daily reconciliation is not performed, resulting in a fraudulent transaction going unnoticed until after the settlement date.
- Transactions are not limited to normal business hours or amounts, resulting in an unnoticed fraudulent transaction.
- Transactions are not monitored or regularly reconciled, resulting in an unnoticed fraudulent transaction.

2.10 Application Hardening

- Default accounts or passwords can be used by attackers to gain unauthorised access to the application.
- Excessive privileges given to application users can be abused by attackers to perform unauthorised actions on the application.
- An attacker uses a vulnerability associated with an unused network protocol (for example, telnet) or functionality provided by unnecessary packages to gain access to a Swift server.

2.11A RMA Business Controls

- RMA relationships are not properly managed, resulting in the processing of a transaction from an unscreened or dormant counterparty.

3.1 Physical Security

- Poor log retention results in the inability to fully investigate which staff had physical access to the safe after a set of Swift HSM tokens were discovered to be missing.

- Weak data centre access control provides unauthorised staff with physical access to perform a physical-based attack on the Swift servers.

4.1 Password Policy

- A password policy is established, but not enforced, resulting in operators using weak passwords that are easily cracked during a cyber-attack.
- A password of insufficient length allows the computation of a weak password hash, which an attacker steals from the PC's memory and allows him to recompute the original password.
- The same passwords are used by an administrator for systems inside and outside the secure zone, resulting in an adversary compromising the more exposed password and re-using this knowledge to gain access to the secure zone.

4.2 Multi-factor Authentication

- Multi-factor authentication is not implemented to access applications, resulting in an adversary using a stolen password to gain full access to the Swift messaging interface.
- Multi-factor authentication is not implemented to access the operating system of the messaging interface, resulting in an adversary using a stolen password to gain full administrative access to the system.

5.1 Logical Access Control

- "Least privilege" controls are not enforced, allowing an operator who only requires read-only access the ability to create and send transactions.
- Separation of duty controls are not enforced, allowing a single operator to create and approve a transaction, conflicting with the user's transaction approval policy.
- Account access is not promptly revoked, resulting in a recently transferred employee using their residual access to modify records on the Swift messaging interface.

5.2 Token Management

- Poor record keeping during assignment of connected and disconnected hardware or personal tokens results in the inability to revoke the correct tokens after staff members leave the organisation, allowing unknown and uncontrolled access.
- A token is left inserted in an operator's PC when not in use, allowing an attacker to use the token as an authentication credential as part of an attack.

5.3A Staff Screening Process

- A new employee with a previous judicial record for financial fraud is not screened before being granted operator access, resulting in an untrustworthy individual being placed in a position of trust.
- Current employees are not periodically screened, resulting in the organisation not having knowledge of an employee who has taken a part-time job with another financial institution and now has a significant conflict-of-interest.

5.4 Password Repository Protection

- A Swift operator stores passwords on a piece of paper at the work area, allowing any staff member with physical access to the area to view the recorded password.
- A Swift application administrator stores administrative passwords in a plain text file on a PC, thus allowing any PC system administrator access to the passwords.

6.1 Malware Protection

- Anti-malware software is not installed on the operator PC, resulting in a common malware executable compromising the PC after clicking a phishing e-mail.
- Anti-malware software on the Swift servers is not regularly updated, resulting in an otherwise detectable malicious executable causing harm to the servers.

6.2 Software Integrity

- An advanced attacker modifies the executable of the messaging interface and is not detected because software integrity checking has not been implemented.
- A malicious version of a software update is installed because the checksum was not verified at time of download.

6.3 Database Integrity

- A lack of database integrity checking allows targeted malware to delete database records while performing unauthorised transactions.
- A lack of database integrity checking allows an attacker to modify database records to hide evidence.
- A lack of database integrity checking allows a gap in sequential record numbering to remain undetected.

6.4 Logging and Monitoring

- Poor system logging results in the inability to trace malicious privileged commands to a specific individual during a cyber incident investigation.
- Logs are collected, but not monitored, resulting in abnormal activity going undetected until significant financial harm has occurred.

6.5A Intrusion Detection

- A lack of intrusion detection capabilities results in unusual traffic outside normal business hours going undetected.
- A lack of intrusion detection capabilities results in unexpected protocol traffic for a given port going undetected.
- The intrusion detection system is not properly configured or monitored, resulting in discoverable intrusions remaining undetected because of the high number of false alarms.

7.1 Cyber Incident Response Plan

- An untested cyber incident response plan results in a poor and uncoordinated response to a serious cyber intrusion, resulting in significant and avoidable financial harm.
- The failure to notify Swift during a cyber incident results in incomplete sharing of information, leading to similar cyber incidents at other institutions that could have been avoided.
- The inability to act upon cyber-threat intelligence leads to cyber intrusions that could have been avoided.

7.2 Security Training and Awareness

- Swift operators are not trained on best security practices, resulting in staff clicking malicious phishing e-mail links.
- Swift application administrators are not trained on security awareness related to their role and, as a result, do not detect or report suspicious activity on the Swift systems.
- Swift security officers lack knowledge related to their role and, as a result, do not properly assign privileges for operators, allowing the bypass of the separation of duties principle.

7.3A Penetration Testing

- Penetration testing is not conducted in the Swift environment, and thus excessively permissive firewall rules are not discovered and corrected.
- Penetration testing is conducted by unqualified staff who are unable to simulate a typical financial industry attacker, which results in a false sense of security and low commitment to needed security improvements.

7.4A Scenario-based Risk Assessment

- Realistic risk scenarios are not tested within the organisation, resulting in an incorrect estimation of likelihood, impact, and overall cyber risk.
- Risk scenarios are tested without involvement of the business units and appropriate management, resulting in poor overall value of the activity and low commitment to needed security improvements.

Appendix D: Glossary of Terms

Term	Definition
Administrator	May refer to: Application Administrators – responsible for configuring, maintaining, and conducting privileged activities through an application interface. System Administrators – responsible for configuring, maintaining, and conducting other privileged activities through operating systems or other direct (non front-end) access.
Alliance Connect VPN Box or Virtual instance	Swift offering to connect to the Swift network. It is composed of two models: SRX and its successor, SSR. For each model, there is a physical/hardware box deployed by the users and a virtual instance only available through the cloud providers approved as per the Swift Cloud Provider Programme. With the new model (SSR), there will be an additional virtual instance option, to be deployed by customers on their premises. That Alliance Connect Virtual on Premises VPN instance is expected to run on a dedicated virtual machine and is explicitly identified as in scope of several controls.
Alliance Connect Virtual (SSR) on Premises VPN instances	Virtual (SSR) VPN instance deployed on Provider's premises in dedicated virtual machines to connect to Swift network. The Virtual on Premises VPN, including its hosting (underlying) virtualisation platform, is explicitly identified as in scope of several controls. It will become available as part of the Alliance Connect portfolio because of the evolution to a new technology between 2026 and 2028.
Ancillary services	Complementary services, such as queries on previous transactions (for instance through the Basic Tracker), pre-validation, conversion or screening performed before submitting business transactions. They are usually considered as out of scope. However, sharing/reusing credentials and roles/entitlements used for business transactions on systems or components used for those ancillary services turns those systems or components in scope.
Application account	Logons designated for an application. They are not meant to be used by a human, through a graphical user interface or interactive access. Application accounts have a password that is stored, retrieved, and used automatically by the application. An application account is typically used for integration purposes (for example, calling of API) or to support STP (straight-through-processing).
Asset class	A category of computing asset (for example, databases, servers, applications).
Back-office first hop	The first back-office system, as seen from a secure zone, a CSP component connects to, or exchanges data with (either directly or through one or a chain of bridging servers). It remains out of scope when not co-hosted with a Swift-related component in the user's Swift infrastructure and not in the secure zone.

Term	Definition
Back-office system	A system responsible for business logic, transaction generation, and other activities occurring before transmission into the user's Swift infrastructure. The back-office system performs tasks such as business transaction creation and formatting (for example in ISO 20022 format), or modification (including fields enrichment/removal or transaction cancellation) before transmission into the user's Swift infrastructure.
Bridging server	A server (such as middleware, file transfer server) used to support the data exchange between the back-office first hop(s) and Swift-related components in the user's Swift infrastructure. The bridging server transfers, transports or distributes data from one system to another. It enables two systems to communicate or relay data using various methods (such as messaging queuing or file transfer). As such, it does not provide a business logic as a back-office does before exchanging data with an interface or a connector. Examples: sFTP, middleware (such as MQ, Kafka) servers or brokers, Message Bus.
Business Connect provider	A Swift partner that is subject to the Enabler programme and is offering a Business Connect solution to facilitate users' connectivity to Swift messaging services.
Business transactions	Business transactions are basically the payment instructions (such as in Swift messaging MT 101, MT 103, MT 202, MT 205, their MX equivalent, pain.001, pacs.008, pacs.009 or any calls acting similarly) or instructions that lead to a payment.
Business transactions management	It relates to activities that create, submit, cancel, stop, recall or modify business transactions or entitlements related to those activities.
Co-hosted components	Components deployed or running on a same physical system or virtual machine (created on a virtualisation or cloud platform). Note that containerised applications are, by default, considered as co-hosted on the same physical system or virtual machine that hosts the container itself (see control 1.3 for more info).
Communication interface	The software providing a link between the SwiftNet network and messaging interface software or a back-office system. Communication interfaces provide centralised, automated, and high-throughput integration with different in-house financial applications and service-specific interfaces. Communication Interfaces are provided by Swift (for example, Alliance Gateway or Alliance Gateway Instant). Communication interfaces holding a Swift-compatible label can also be provided by third-party vendors.
Connector	A local software designed to facilitate communication with an external messaging or communication interface, with Swift, or with a service shared by a service provider. When using a connector, interface components are usually offered by a Swift connectivity provider, a remote Group Hub, or Swift. In some cases, a service provider, including a Business Connect provider or a third party such as an outsourcing agent, can also run a connector. It refers to both Swift connectors and customer connectors.

Term	Definition
Customer client connector	The application or footprint residing on a system (such as an endpoint consuming APIs, a middleware, or a file transfer client) used to connect to a Swift connectivity provider, an outsourcing agent shared service, a remote Group Hub, or Swift. With the introduction of the 'customer client connector', the 'customer connector' will gradually cover both a server or a client endpoint connecting to a Service Provider or to Swift. As such, the term 'customer (client) connector' is sometimes also used to cover all the types of customer connectors (that is, server and client).
Customer connector	File transfer solutions or middleware servers (such as IBM® MQ, Apache Kafka or Solace servers/brokers) or clients used for external communication or connection are considered customer connectors as opposed to Swift-compatible products (such as communication and messaging interfaces or connector) delivered by Swift or related third-party vendors that are considered as Swift connector. An application integrating all functionalities to directly and independently connect to the Swift API Gateway to process transactions is also considered as a customer (in-house API) connector. The 'customer facing' webservers used by Swift WebAccess service providers to support their WebAccess service, are also considered as customer connectors. With the introduction of the 'customer client connector', the 'customer connector' will gradually cover both a server or a client endpoint connecting to a Service Provider or to Swift. As such, the term 'customer (client) connector' is sometimes also used to cover all the types of customer connectors (that is, server and client).
Common Vulnerability Scoring System (CVSS)	An open industry standard for assessing the severity of software vulnerabilities by assigning severity scores to these vulnerabilities, allowing for prioritisation of responses and resources in line with the threat.
Cyber-security incident	Any malicious act or suspicious event that compromises, or was an attempt to compromise, a computing environment.
Data exchange layer	The transporting of data between the Swift-related components (in the user's Swift infrastructure or at a service provider) and a user back-office first hop, at application level, as seen from the Swift-related components.
Dedicated operator PC	An operator PC located in the secure zone and dedicated to interact with components of the secure zone.
Endpoint Detection and Response (EDR)	An emerging technology that addresses the need for continuous monitoring and a response to advanced threats by detecting suspicious activities and (traces of) other problems on systems/endpoints.
Endpoint Protection Platform (EPP)	An emerging solution to address attack prevention. More frequently combines with EDR.
End User	An individual requiring interactive access to the application (for example, for business transactions, monitoring, and access control). This includes security officers and application administrators responsible for configuring and maintaining the application.

Term	Definition
Four-Eyes principle	A security principle whereby two individuals must approve an action before it can be taken. This principle is also known as two-person rule.
General (enterprise) IT environment	The infrastructure used to support the broad organisation. This includes general IT services and general-purpose operator PCs.
General IT services	The supporting IT infrastructure, such as authentication services, asset management, databases, data storage, security services (for example, patching), networking services (for example, DNS, NTP) or servers supporting the Change and Release Management, including Infrastructure as Code (IaC).
General-purpose operator PCs	A PC or device located in the general enterprise environment and used for daily business activities: - as an operator: to use, operate, or maintain the user's Swift infrastructure residing on premises or externally hosted or - as a user: to use a remote Swift infrastructure or application operated by a service provider or Swift or - a combination, depending on the architecture type.
Graphical user interface (GUI)	A software that produces the graphical interface for a messaging interface, a communication interface or a connector (for example, Alliance Web Platform, CREST WebGUI+, Swift Microgateway Front-End, and equivalent products).
Group Hub	A Swift user or a non-Swift user organisation connecting Swift users within its corporate group. A Group Hub is considered as a specific service provider for the related users and not a third party.
Hardware token	A USB token, smart card, or similar device.
Hardware Security Module (HSM)	Swift Hardware Security Modules store the users private keys necessary for the signing (encrypting) operations. A new HSM model (Luna SA7) is available and will progressively replace the existing HSM model (Luna IS6). While such replacement maintains the same level of security, the HSM is clearly identified as in scope of all the relevant controls. As such: - The term "HSM", refers to both existing (Luna IS6) and new models (Luna SA7) –no change. - The term "New HSM" is used as heads-up when newly identified as in scope component of several controls. This to facilitate the transition while it is expected they are already covered with the existing model. Consequently, those controls need to be formally taken into account when installing, using the new HSM model (Luna SA7 as per documentation) and further assessing compliance with those controls. - At the end of the HSM migration, the term "new" in "new HSM" will disappear and "HSM" will remain.
Hosted database	The terminology used when a (user) database server or infrastructure (such as Oracle or the like) is used as opposed to an "embedded database" incorporated in the messaging interface itself.
Indicators of compromise (IOC)	Artefacts that can be observed on a network or operating system that might indicate system compromise.

Term	Definition
Interactive login / session	The session model that indicates an exchange of data (for example, when a user enters data or a command and the system returns data).
IT services	A set of components in support of business processes inside the secure zone, such as a release and patching deployment platform, Active Directory.
Jump server	A server used to provide access to the user secure zone from the user's corporate network (for example, Citrix or Remote Desktop).
Key Management Service or System (KMS)	Solution designed to store, manage, and retrieve cryptographic keys securely and effectively. KMS can support different sorts of keys, varying from platform to platform.
Local Authentication (LAU)	The mechanism that provides integrity and authentication of files exchanged between applications. Local Authentication requires that the sending and receiving entity use the same key to compute a Local Authentication file signature.
Luna Backup HSM	Optional device used to back up and restore the HSM primary keys (also known as Secret Master Keys, SMKs). Due to the sensitivity of the SMKs: (i) The Luna Backup HSM, a removable equipment, must be protected in line with the control 3.1 and (ii) The credentials controlling the access to the back-ups must be protected in line with the control 5.4.
Messaging interface	A software supporting the use of MT, MX, or ISO 20022 message standards through Swift FIN, InterAct, FileAct, and SwiftNet Instant messaging services. The software provides the means for users to connect business applications to Swift messaging services and is typically connected directly to the communication interface (the decision tree can also be used to identify the intricate cases of components connecting to the communication interface). Messaging interfaces are provided by Swift (for example, Alliance Access, Standalone Alliance Access, Alliance Messaging Hub or Alliance Messaging Hub Instant). Messaging interfaces holding a Swift-compatible label can also be provided by third-party vendors.
Middleware	A software that enables two separate programs to interact or to exchange data with each other (for example, IBM® MQ, BizTalk, ConnectDirect, Apache Kafka, Solace PubSub+). Usually composed of a Server and Clients running on the various interconnected systems (Client-Server model). In the case of peer-to-peer model without central server, connectivity can be considered as being direct between the systems (so not through middleware).
Middleware client	The client part used by an application or system to interact and exchange data with the middleware server (such as an IBM® MQ or Apache Kafka client).

Term	Definition
Middleware server	Local middleware systems implementations, such as IBM® MQ server (including MQ queues manager, MQ appliance or both), Apache Kafka or Solace server/broker or other systems, used for data exchange or transport between the Swift-related components (in the user's Swift infrastructure or at a service provider) and a user back-office first hop as seen from the Swift-related components. It is an example of bridging server.
Multi-factor authentication	A method of user authentication where at least two different components are required to authenticate a user. The following authentication factors can be selected: • Knowledge factor (something the user knows), for example, a PIN or a password • Possession factor (something the user has), for example, an HSM token, a Digipass, mobile phone, 3-Skey Digital and its mobile version, or an RSA One Time Password device • Human factor (something the user is), for example, finger print or any other biometric
Network access control list (ACL)	The list of rules that are applied to port numbers or IP addresses for controlling traffic in and out. These lists are available on a network device.
Network devices	Components, dedicated or shared, used to assist in the management, routing, and security of the network (for example, routers, switches, firewalls) within or surrounding the user's Swift infrastructure and protecting the secure zone or the customer client connectors.
Non-Swift footprint	A component deployed in user environment to link with Swift messaging services, Swift Transaction Manager, or a service provider, and that is not a messaging interface, a communication interface or a connector delivered by Swift or a related third-party vendor. Examples are file server solutions, middleware servers or clients or customer (in-house API) connector.
(SwiftNet) Online Operations Manager (O2M)	A Swift web Access service that enables user certificates and roles management as part of Security Officers' entitlements
Operating system (OS) accounts	User accounts on a server or PC that are used for direct access to the operating system.
Operator	The term that collectively refers to both individual types below: End users – individuals requiring interactive access to the application (for example, for business transactions, monitoring, and access control). This includes security officers and application administrators responsible for configuring and maintaining the application. Operating System Administrators – responsible for configuring, maintaining, and conducting other privileged activities on the operating systems hosting the user's Swift infrastructure.

Term	Definition
Operator PC	A PC or device used for daily business duties: - as an operator: to use, operate, or maintain the user's Swift infrastructure residing on premises or externally hosted or - as a user: to use a remote Swift infrastructure or application operated by a service provider or Swift, or - a combination, depending on the architecture type.
Outsourcing agent	An outsourcing agent is a third-party organisation to whom Swift users delegate one or more of the following tasks: hosting, installation, operation and maintenance of components involved in their Swift connectivity, all components being subject to the CSP program. Those components may cover interfaces, Swift or customer connectors or a Swift-related application as defined in the Customer Security Controls Framework (CSCF). See also the Outsourcing Agents Security Requirements Baseline for more details.
Personal Identification Number (PIN)	A secret number that acts like a password preventing others from gaining unauthorised access to or using a token, mobile device or card.
Privileged account	An account on an operating system or application that gives elevated access beyond that of a typical user. A privileged account includes administrator accounts on operating systems, and security officer (such as Alliance Left and Right Security Officer, LSO/RSO) or application owner accounts on applications (including the activation account used for their installation).
Reasonable comfort	A level of comfort that Management can obtain from internal or external subject matter experts (SME) when: - appropriate level of independence and objectivity of the SME is ensured, - fair validation by the SME of control design and implementation, confirms mitigation of risks as in the control objective, and - noted deviations do not materially impact the control's ability to mitigate the risk, or alternative controls compensate for such deviations. External assessments and certifications (such as against Systems and Organizations Controls (SOC) 2 or any industry standard identified in Appendix E like NIST or PCI-DSS) that cover CSCF controls, can give Management such reasonable comfort about the appropriateness of the controls as well as their operating effectiveness. The scope of this evaluation and the approach used for control evaluation in the context of such external assessments or certifications must be understood before relying on them either partially or fully.
Relationship Management Application (RMA)	A filter that enables the user to limit the correspondents from which messages can be received and the type of messages which can be received. The use of the Relationship Management Application mechanism is mandatory for the FIN service. It is available on an optional basis; when using local RMA, for SCORE FileAct and Generic FileAct.
Remote access	The access to a computer from outside the user's network. For example, from home or from another organisation's network.

Term	Definition
Remote login	A login to a system initiated over a network connection rather than directly from the user's network.
Secure Channel	An application on swift.com on which security officers can view interface licence keys and manage their institution's security officers, the Secure Code Cards, and SwiftNet offline interventions.
Secure zone	A secure operational (sometimes also called production) zone on user premises separated from the general enterprise. The secure zone contains Swift-related systems (for example, messaging interface, communication interface, connectors), and, optionally, other protected systems.
Server Environment	A data centre or other secured physical location hosting servers.
Service bureau	A Swift user or non-user organisation that provides services to connect Swift users. The services offered by a service bureau typically include sharing, hosting, or operating Swift connectivity components, logins to the infrastructure, or managing sessions or security on behalf of Swift users. Service bureaux are subject to the Shared Infrastructure Programme.
Service provider	Generic term that encompasses third parties, Swift connectivity providers and Group Hubs (see section F Outsourcing of Scope of Security Controls for a visual representation).
Simple Object Access Protocol (SOAP)	An XML-based messaging protocol for exchanging information among computers.
Single user or safe mode	The protected mode of operation that limits the privileges of the user.
Software token	An authentication token in logical (software) form.
Staff	All individual people who collectively work for the same organisation (such as employees, agents, consultants and contractors).
Swift Connectivity Provider (SCP)	It includes organisations such as service bureaux, Business Connect or Lite2 Business Application providers subject to respectively the Shared Infrastructure Programme, the Enabler and L2BA programme. Those organisations typically provide sharing, or operating Swift connectivity components, logins to the infrastructure, or managing sessions or security for Swift users.
Swift connector	A connector provided by Swift (for example, Swift Integration Layer (SIL) Direct Link, Alliance Lite2 AutoClient or Swift Microgateway). A connector holding a Swift-compatible label provided by a related third-party vendor.
Swift footprint	A messaging interface, a communication interface or a connector provided by Swift or holding a Swift-compatible label and provided by a third-party vendor.
Swift-related application	Swift-related components or a (web) application exposed by a Swift connectivity provider or an outsourcing agent to support business transactions or payments related activities (creation, modification, approval, deletion of transactions). A Treasury Management System (TMS) is an example of such exposed (web) application.

Term	Definition
Swift-related component	A software, product or element, usually deployed in a user's infrastructure or secure zone, that supports Swift messaging and transactions services. Messaging and communication interfaces, SNL, Swift and customer (client) connector, HSM, tokens, GUI as defined in the Scope of Security Controls section are examples of Swift-related components. Network devices protecting the secure zone can by extension also be considered as Swift-related components but they are specifically mentioned when expected to be in-scope of a control.
Swift-related system	A system (physical box or virtual machine) running a Swift-related component.
Thick client	A software program installed and executed on the local operator PC, rather than using a browser interface.
Third party	An entity independent of the Swift user or of the user's Swift connectivity provider that provide services to a user. For example, an external IT provider, a cloud provider or an outsourcing agent which can also be an IT provider or a cloud provider as per the Outsourcing Agents Security Requirements Baseline. By default, Swift connectivity providers (service bureaux, Business Connect and L2BA providers) are not considered as third parties, unless the Swift user specifically engages with them to host or to operate, or both, in full or in part the user's Swift infrastructure (still owned by the user).
Transaction Authentication Number (TAN)	A type of single-use password generally used with a standard ID and password. Initially presented in a list or table.
Transaction business control solution	A transaction business controls solution is used to screen (for AML, sanctions or other compliance purpose) or detect potentially fraudulent payments. The solution is also used to review the identified suspicious transaction payments and decide whether they can be cancelled or released. Note: The general-purpose operator PCs used to either configure the solution, cancel or release payments or a combination of those actions, are part of the CSP scope.
(Swift) Transaction Manager	The platform deployed centrally by Swift to offer complete transaction management in line with the strategy endorsed by the Board in March 2020.
Transport Layer Security (TLS)	A cryptographic protocol that secures communications by offering confidentiality, integrity and protection against replay attacks measures.
(Swift) User	An organisation that Swift has admitted under the Corporate Rules as a duly authorised user of Swift services and products. The eligibility criteria to become a Swift user are set out in the Corporate Rules.
User application accounts	User accounts established at the applications layer to grant access and permissions to the application (that is, not operating system accounts).

Term	Definition
User's Swift infrastructure	The collection of, on-premises or remote (that is hosted or operated, or both by a third party), Swift-specific components managed by of for the user. Those components include applications, network devices, tokens and other removable media or equipment, and supporting hardware. Also known as the Swift or customer secure zone.
Extended Detection and Response (XDR)	New technology approach to threats detection and response that extends beyond end points by collecting and correlating activity data across multiple security layers (endpoints and other servers, across networks, clouds, and applications).

Appendix E: Mapping to Industry Standards

The Knowledge Base article [5026074](#) maps the Swift security controls against different international security standard frameworks (such as NIST Cybersecurity Framework v1.1 and later v2.0, ISO 27002 2022 or PCI DSS 4.0). The article has also been enriched with mappings against the SOC2 TS 2017 and the Unified Compliance Framework (UCF) standards.

The mapping table referred to in the article provides further details on how the Swift security controls map to similar controls in those industry standards. If users are certified against any of these standards and under the condition that the Swift infrastructure is in the scope of this certification, then the table indicates how the controls from these standards map to the Swift security controls.

As to other standards, Swift suggests using the informative references provided by NIST in the document Framework Core of their Cybersecurity Framework v1.1 (Appendix A) provided in the referred mapping table.

Important Note:

Meeting requirements from these industry security standards does not automatically imply full compliance with the Swift security controls. Some aspects of the controls might not be covered in the standard. It remains the ultimate responsibility of the user to assess whether and to which extent the compliance with one of these industry standards is suitable to assess the compliance with the Swift security controls.

Appendix F: Services and Components in scope per architecture type

To help users to identify the most important elements, the table below (version 2021_1.0) presents the services and components expected to be in scope and the usually related architecture type. It also presents, for informational purposes only, usual elements that are not in scope.

Note: This table will continuously be updated through the year. It is recommended to always use the latest version that can be found in the Knowledge Base article [5024040](#) (CSP Components).

The following elements have to be considered when using the table:

- If multiple components are owned by a user and these components have different architecture types, then the user has to attest in KYC-SA against the most comprehensive architecture type using the [decision tree](#), if needed.
- A component that is co-hosted with a component in scope is considered as in scope.
- All the components located in a secure zone have to be secured to the same level.
- <CTRL F> represents the most convenient way to locate a product.
- Components are listed alphabetically within each category.
- <effective date> refers to the date as of which a newly introduced component must be taken into account for the CSP Assessment. If empty, then it means it must already be taken into account.
- A, B – The Architecture type can be any “A” or “B”.
- N/a – Not applicable.
- Swift recommends protecting components that are out of scope as if they were in scope.

In Scope/Not in CSP Scope	Category	Component Name (alphabetical within each category)	Description/Remark	Likely CSP Architecture Type(s)	Effective date
	Interfaces and Related Applications	Communication interface (for example, Alliance Gateway, Alliance Gateway Instant (AGI))	List of compatible communication interface: here Also includes API connectivity functionality based on AGI or Alliance Gateway	A1	
		Graphical user interface (GUI)	Products such as Alliance Web Platform (AWP), CREST WebGUI+ (Euroclear's GUI webserver), Swift GPI GUI. Swift does not ensure compatibility of GUI provided by Vendors	A	
		IPLA – Alliance Access Integration Platform	Built on top of Alliance Access. IPLA is expected to reach end of live in 2026 but remains in-scope till then	A1/A2	
		IPLA – Connector for ESMIG	Connector for ESMIG is an IPLA component on Alliance Access. IPLA is expected to reach end of live in 2026 but remains in-scope till then	A1/A2	
		Messaging interface (for example, Alliance Access, Standalone Alliance Access, Alliance Messaging Hub (AMH))	List of compatible messaging interface: here . The CREST Gateway based on Alliance Access is considered as a messaging interface. Some back-office systems can be considered as messaging interface (See KB article 5021823)	A1/A2	
		MQHA in relax/strict mode	Back-office system or application using the MQHA in Relax and Strict mode are considered as messaging interface	A1/A2	
		RAHA in relax/strict mode	Back-office system or application using the RAHA in Relax and Strict mode are considered as messaging interface	A1/A2	
		Relationship Management Application (local RMA)	Can be stand-alone or integrated in the Alliance Access or AMH or vendor product –(see also here). The RMA Portal operated by Swift is out of scope as such. When the RMA Portal is used, the equipment (such as the operators PCs and tokens) used to connect to it for central management of the relationships is in scope.	A1/A2	
		SwAP Proxy (GPI Connector) on AMH	GPI Connector on AMH is an AMH service running within AMH infrastructure (runs within AMH)	A1/A2	
		Remote File Handler (RFH) – FileAct	This component is used to transfer files and is installed in the messaging interface. Sometimes also referred by its executable name: SWFA Handler	A1/A2	
		Alliance Access used to connect to Alliance Remote Gateway (ARG)	This is an Alliance Access solution hosted on customer premises and accessing the Alliance Cloud solution at Swift.	A2	
		SwiftNet Link (SNL)	Can be either included in the communication interface or stand-alone.	A1	
		Swift Translator (embedded)	The Swift Translator runtime is a component that is called (integrated) locally by the messaging interface to perform message validation or message format translation (such as MT to ISO or Proprietary to ISO); Out of Scope when stand-alone and kept outside of the secure zone	A1/A2	
	Swift Connector	Alliance Lite2 AutoClient	This is the file base solution interfacing with Swift Lite servers	A3	
		Swift Integration Layer (SIL) – Alliance Cloud	This is the solution that replaces the AutoClient solution based on Direct Link. SIL is expected to reach end of Live in 2026 but remains in-scope till then	A3	
		Swift API Connector	Includes products such as Direct Link/SIL or Swift Microgateway. SIL is expected to reach end of Live in 2026 but remains in-scope till then	A3	
		Swift Microgateway	Provides API connectivity functionality.	A3	

In Scope/Not in CSP Scope	Category	Component Name (alphabetical within each category)	Description/Remark	Likely CSP Architecture Type(s)	Effective date
	Customer Connector	Customer API connector	Customer in-house API connector including API connectivity functionality, based on Swift API SDK or their specifications	A4	
		sFTP or FTPs solutions (servers or clients)	Secure File transfer solutions used to facilitate communication with Swift-related components offered by a Swift connectivity provider or an outsourcing agent.	A4	
		Middleware Server or Client	Includes local middleware systems implementations, such as IBM® MQ, Apache Kafka or Solace server/broker, or their respective clients used for data exchange/connectivity with a Swift connectivity provider or an outsourcing agent.	A4	
		WebAccess servers at provider side	The 'customer facing' webserver hosted and operated by Swift WebAccess service providers. The Swift WebAccess service providers have to consider those webserver as customer connectors , protect them accordingly and include them in the scope of their KYC-SA attestation and in the supporting assessment. Such webserver can only be descoped from the CSP if i) the supported WebAccess services are read-only (that is, used for queries only) and ii) the disclosure of transactions to external bodies or to other not involved participant(s) of the service does not affect the reputation of the Swift WebAccess service provider. Any descoping must be confirmed by the independent assessor.	A	
	Hardware Components	Alliance Connect (SRX and SSR Hardware) VPN boxes or Alliance Connect Virtual (SRX and SSR on Public Cloud) VPN instances (hosting systems or machines)	Only the CSP control 3.1 Physical security applies to the physical boxes. Controls 3.1 and 1.3 Virtualisation or Cloud Platform Protection apply to the Alliance Connect Virtual VPN instances deployed on the cloud providers approved as per the Swift Cloud Provider Programme.	A, B	
		Alliance Connect Virtual (SSR) on Premises VPN instances	Virtual (SSR) VPN instance deployed on customer's premises in dedicated virtual machines to connect to Swift network. The Virtual on Premises VPN, including its hosting virtualisation platform, is explicitly identified as in scope of several controls. It will become available as part of the Alliance Connect portfolio because of the evolution to a new technology between 2026 and 2028.	A, B	
		Connected and disconnected hardware authentication or personal tokens	Connected and disconnected hardware authentication or personal tokens used for Swift operations or secure zone access and PIN Entry Device (PED) used for HSM operations. Includes the 3SKey personal tokens when used for Swift services (such as FIN, InterAct, FileAct in direct or through Alliance Cloud, Lite2 and in the future a messaging service or the Transaction Manager exposed by Swift).	A, B	
		Hardware Security Module (HSM)	Typically combined with SwiftNet Link SNL. There are 2 models of HSM in the field: IS6 model which is progressively replaced by the new SA7 model.	A1	
		Luna Backup HSM	An optional device and a removable equipment, used to back up and restore the HSM primary keys (also known as SMKs). Due to the sensitivity of the SMKs, this device must be safe stored (as per the control 3.1) as well as the credential securing the access to the back-up SMKs protected (as per control 5.4).	A1	
		Network devices protecting the secure zone(s) or the customer client connector(s)	Includes firewalls and routers.	A	

In Scope/Not in CSP Scope	Category	Component Name (alphabetical within each category)	Description/Remark	Likely CSP Architecture Type(s)	Effective date
		Remote PED Devices	Tokens and physical device used for Remote PED operations	A	
		Virtualisation Platform (Hypervisor)	Underlying layer on premises or with IT or cloud providers hosting Swift-related virtual machines (VMs).	A, B	
	Operator PCs and Operators	Dedicated operator PC	An operator PC located in the secure zone and dedicated to interact with components of the secure zone.	A	
		General-purpose operator PC accessing the on-premises or remote Swift infrastructure and the operators	An operator PC located in the general enterprise environment and used for daily business activities.	A, B	
		(Dedicated or) General-purpose operator PC used by CREST WebGUI+ users	An operator PC used to access the CREST WebGUI+ (Euroclear's browser-based solution or GUI webserver) that includes the CREST WebAPI. The CREST WebAPI uses the CREST Network Security Layers (NSL) stack through the so-called WebNSL (a Swift module), to access the CREST Gateway which is an Alliance Access based software.	A	
		(Dedicated or) General-purpose operator PC used by CREST GUI users	An operator PC that uses the CREST Network Security Layer (NSL) stack. It is also known as a CREST GUI and used to interact with the CREST Gateway which is an Alliance Access based software.	A	
	Operator PCs and Operators	General-purpose operator PC used to access Swift Messaging Services	General-purpose operator PC used to access Swift Messaging Services hosted and operated onsite at a third party, a Swift connectivity provider, a Group Hub or Swift and when those PCs are used to submit or affect business transactions.	B	
		General-purpose operator PC used by Alliance Cloud or Lite 2 GUI Users	GUI users only do not have a connector.	B	
		General-purpose operator PC used by Business Connect or L2BA GUI Users	This covers PC that remotely connect to a front-end application (or solution) operated by a Business Connect or an L2BA provider	B	
		General-purpose operator PC used by ESMIG user-to-application users	These are PCs connecting to the European Single Market Infrastructure Gateway (ESMIG) application over the Swift Network	B	
		General-purpose operator PC connecting to Swift Transaction Screening Service cloud solution (TSS)	Transactions Screening Service uses central copy service. The solution is used to review the transactions in blocking or non-blocking mode. Where blocking mode is selected, the service is used to abort or release the transaction. The general-purpose operator PCs used to either configure the solution, abort or release payments or a combination of those actions, are part of the CSP scope.	A, B	
		General-purpose operator PC connecting to Swift Payment Controls Service cloud solution (PCS)	Payment Controls Service uses central copy service. The solution is used to review payment instructions identified as potentially fraudulent or out-of-policy according to user-defined criteria. This can be done in blocking or non-blocking mode. Where blocking mode is selected, the service is used to abort or release the payment. The general-purpose operator PCs used to either configure the solution, abort or release payments or a combination of those actions, are part of the CSP scope.	A, B	
		General-purpose operator PC connecting to a transaction business control solution (on-premises, remote or in the cloud)	Other ancillary transaction business control solutions may be used to screen transactions for AML, fraud, sanctions or other compliance purposes. These solutions can also be used to review and make disposition decisions on whether the transaction, payment is aborted or released. The general-purpose operator PCs used to either configure the solution, abort or release payments or a combination of those actions, are part of the CSP scope.	A, B	

		General-purpose operator PC connecting to WebAccess services	Using Web Platform/Alliance Gateway/SNL - over MV-SIPN	A1	
		"	Using Browser/Tokens - over MV-SIPN	B	
		"	Using Browser/Tokens - over the Internet	B	
		General-purpose operator PC accessing the GPI Basic Tracker or the RMA Portal with management/update role(s)	Using Web Platform/Alliance Gateway/SNL - over MV-SIPN	A1	
		"	Using Browser/Tokens - over MV-SIPN	A, B	
		"	Using Browser/Tokens - over the Internet	B	
	MI products footprint used for Specific Swift Service	CRNet in Alliance Access	The CRNet component provides the user with a number of controls over the network connection from Alliance Access to the CRNet host application. It contains the underlying processes required for file transfer and interactive services.	A2	
		MI Channel for Continuous Link Settlement (CLS)	Market Infrastructure (MI) Channel is a messaging channel designed to enable customers to access large market infrastructures in an efficient manner. MI Channel relies on the SwiftNet store-and-forward platform, and optimises the exchange of large amounts of data between the market infrastructure and their participants, while offering a simplified mode of operation and facilitating integration. MI Channel functionality is integrated within the existing communication interface: SwiftNet Link and Alliance Gateway.	A1	
		MI Channel for T2S	Software that manages the full communication stack for connecting to the T2S gateway in the Swift OPC specific to EuroClear.	A1	
		Minimum Foot print (MFP)	This solution is offered in two flavours: (i) embedded in SNL or (ii) as stand-alone, replacing the Alliance Access-Alliance Gateway-SwiftNet Link, in both cases, they are in scope of the CSP.	A1	
		Transaction Delivery Agent (TDA)	The transaction delivery agent is an application, running on top of Alliance Gateway. It provides the transfer of messages between institutions. This transfer method offers a single guaranteed delivery of messages in sequence, without any duplication. The transaction delivery agent interface used to communicate with the applications of the institutions is based on the standard IBM WebSphere MQ messaging middleware.	A1	
	Others	Data Exchange Layer	The transport of data between the Swift-related components (in the on-premises user's Swift infrastructure or onsite at a Swift connectivity provider or at an outsourcing agent) and a user back-office first hop as seen from the Swift-related components. Applicable controls: 2.4, 6.4, 6.5A, 7.3A.	A, B	
		Jump server giving access to the secure zone(s)	A server used to provide access to the user secure zone from the user's corporate network (for example, Citrix or Remote Desktop).	A	
		SOAP/API to connect from a back-office application to the messaging interface at a Swift connectivity provider or at an outsourcing agent	The SOAP connection method enables the exchange of MT, XML-based messages, and FileAct messages between Alliance Access and back-office applications.	B	
	Not in scope	3Skey	A Swift personal identity solution based on PKI technology. 3SKey tokens can be used with all banks to sign and approve transactions. 3SKey can be used on any electronic banking channel including in-house cash or treasury management systems, web banking, local and proprietary networks and Swift. You can use it	N/a	

		to sign electronically banking instructions or connect securely to your banking application. Note that 3Key personal tokens used for Swift services are in scope (refer to Hardware Components category above)		
	Alliance WareHouse (AWH)	AWH is an application used to store long term messages and does not enable messaging operations. Note that while not in scope of the CSCF as such when it is hosted outside a secure zone, the feeding of AWH (from the messaging interface) is subject to control 2.5A External Transmission Data Protection.	N/a	
	Australia New Payments Platform (AU-NPP) and Go Local India (GLI) users	Not considered as Swift users.	N/a	
	The back office	The systems responsible for business logic, transaction generation, and other activities occurring before transmission into the user's Swift infrastructure. For example, back-office implementations such as SAP and General Ledger are out of scope.	N/a	
	Business Intelligence systems (for example, Swift Scope)	Although globally out of scope, Swift recommends the Business Intelligence systems defined as destination for transmitted sensitive data to be included in the control '2.5A External Transmission Data Protection'.	N/a	
	Connections to the Swift network supplied by Swift Network Partners	This includes the (i) Connection to the four Swift providers (BT Global Services, Orange Business Services, AT&T and Colt) behind the VPN Boxes, (ii) Internet connections and (iii) connections through Alliance Connect Virtual established by a Cloud Provider approved as per the Swift Cloud Provider Programme.	N/a	
	sFTP or FTPs solutions (client) on back-office system	Secure File transfer solutions through a client only, used to facilitate communication with on-premises Swift-related components.	A	
	General Enterprise IT environment	The general IT infrastructure used to support the general organisation (for example, general-purpose PCs, mail server, directory services)	N/a	
	General-purpose operator PC accessing the GPI Basic Tracker or the RMA Portal with viewer/read only role	When using swift.com accounts only for Basic Tracker functionalities. It is not used for Stop and Recall. Similarly, viewer role only on RMA Portal doesn't allow for any update. The RMA Portal operated by Swift is out of scope as such. When the RMA Portal is used, the equipment (such as the operators PCs and tokens) used to connect to it for central management of the relationships is in scope.	N/a	
	MQ, Kafka or Solace Client on back-office system	This is a software component that enables an application running on a system to issue calls to a queue manager (MQ Server) or a broker (Kafka/Solace) running on another on-premises system. The output from the call is sent back to the client, which passes it to the application.	N/a	
	MQHA in Basic mode	Back-office application using the MQHA in Basic mode are considered as back-office.	N/a	
	RAHA in Basic mode	Back-office application using the RAHA in Basic mode are considered as back-office.	N/a	
	Payment Gateway/Domestic Messaging Channel (PAG/DMC) for AU-NPP	Not considered as Swift users.	N/a	

	Swift Payment Control Service (PCS)	A solution used to identify and review potentially fraudulent or out-of-policy outgoing payment instructions in blocking or non-blocking mode (without capability to initiate or modify payments). Swift recommends the tokens associated to this service to be covered in the control 5.2 Token Management. Note: The general-purpose operator PCs used to either configure the solution, abort or release payments or a combination of those actions, are part of the CSP scope.	N/a	
	Pre-validation for Swift GPI	The GPI pre-validation detects payment problems before payments are sent for execution. There is consequently no specific risk in terms of CSP. The GPI pre-validation uses the Swift API Gateway. It must authenticate with the Swift API platform, which can be facilitated by using dedicated technology, such as the connector for Swift GPI. It can be based on SDK, SDK + GPI stand-alone connector, or by using interfaces and an embedded GPI connector.	N/a	
	Pre-validation GPI webserver	Used for queries only and does not impact the integrity of the transactions.	N/a	
	Swift Scope	A business intelligence solution providing full and immediate visibility on an organisation's daily cash reporting.	N/a	
	Swift SDK on back-office application (when relying on Swift footprint or customer connector)	Not in scope when relying on other Swift-related components to connect to Swift Messaging/Transaction Services (using a communication interface or a Swift (API) connector as Swift footprint).	N/a	
	Swift Translator (stand-alone)	Out of scope when stand-alone and not in the secure zone. In-scope when embedded in the messaging interface.	N/a	
	Swift Transaction Screening Service (TSS) using central copy service - cloud solution	A solution used to screen transactions for sanctions compliance where blocked payments can be reviewed in Transaction Screening and aborted or released. End users do not initiate or modify payments in Transaction Screening. If a payment is released then it means that it has passed all transaction controls in the messaging interface (for example, Four-Eyes, Six-Eyes) and this is just an additional check for compliance purposes with those regulatory lists (UN, States, and other lists). End users use WebAccess to access the Transaction Screening GUI in the cloud. Swift recommends that the tokens associated to this service be covered in the control 5.2 Token Management. Note: The general-purpose operator PCs used to either configure the solution, abort or release payments or a combination of those actions, are part of the CSP scope.	N/a	
	Other transaction business controls solutions	Other ancillary transaction business controls solutions may be used to screen transactions for AML, fraud, sanctions or other compliance purposes. These solutions can also be used to review and make disposition decisions on whether the transaction, payment is aborted or released (without capability to initiate or modify payments). Note: The general-purpose operator PCs used to either configure the solution, abort or release payments or a combination of those actions, are part of the CSP scope.	N/a	

Appendix G: Shared Responsibilities in a Cloud Model

Users that engage with third parties (such as an external IT provider, a cloud provider, or an outsourcing agent) to host or operate their own Swift infrastructure in full or in part, must get reasonable comfort from those third parties that the related activities are protected in line with CSCF security controls. As such, third parties can rely on their compliance programme that usually builds on SOC 2, PCI-DSS or NIST certifications or assurance to answer users engaging with them and to map the CSCF security controls. As an example, cloud providers approved as per the Swift Cloud Provider Programme, are, per the programme, providing a similar conformance statement to their subscribing users. The user remains responsible and accountable for the attestation they need to fill taking into account the deployed controls and those deployed by the involved third parties and service providers.

The below drawing presents the usual sharing of the responsibilities between a user and a cloud provider.

				User Manages
				Provider Manages
On premises	IaaS Infrastructure as a service	PaaS Platform as a service	SaaS Software as a service	
Applications	Applications	Applications	Applications	
Data	Data	Data	Data	
Runtime	Runtime	Runtime	Runtime	
Middleware	Middleware	Middleware	Middleware	
OS	OS	OS	OS	
Virtualisation	Virtualisation	Virtualisation	Virtualisation	
Servers	Servers	Servers	Servers	
Storage	Storage	Storage	Storage	
Networking	Networking	Networking	Networking	

Not all outsourcing models can be covered here. Therefore, to illustrate and trigger users' choice when considering the outsourcing model, the table below presents the typical sharing of responsibilities when an Infrastructure as a Service (IaaS) model in the cloud is selected. In such scenario, the user subscribes to a virtualised environment set up by selected cloud providers (CP) on the cloud infrastructure. The user remains responsible for the deployment, management of the various stacks (systems and applications) in the subscribed environment and, therefore, of the related controls. The HSM has to be physically hosted (on-premises or in a co-location data centre). If the majority of the systems or components of an architecture A1 are hosted with the cloud provider, then the user still has on premises some equipment, as a minimum the operator PCs, that they need to protect.

It is also recommended to consult the outsourcing agent documentation that is available on the [Knowledge Centre \(swift.com\)](https://www.swift.com/knowledge-centre).

Control	User	CP	Relevance for the Cloud Provider (CP)
1.1 Swift environment protection.	X	X	Separated virtualised user environment [mainly through 1.1.c by design, network & operations]
1.2 OS privileged accounts control.	X	X	On the virtualisation infrastructure/environment set up by the CP
1.3 Virtualisation platform protection	X ^{if used}	X	Supporting the virtualisation infrastructure/environment set up by the CP.
1.4 Restriction of internet access.	X	X	Protection of the virtualisation infrastructure/environment set up by the CP
1.5 Customer environment protection.	X	X	Separated virtualised user environment [mainly through 1.5.c by design, network & operations]
2.1 Internal data flow security	X		
2.2 Security updates.	X	X	On the virtualisation infrastructure/environment (and admin desktop)
2.3 System hardening	X	X	On the virtualisation infrastructure/environment (and admin desktop)
2.4 Back Office data flow security.	X	X	Secure exchange with the virtualisation infrastructure/environment and subscription of the user
2.5A External transmission data protection.	X	X	Virtualisation infrastructure/environment back-ups and transfers (between virtual stacks). Protect data storage (ideally through encryption – data at rest or environment/subscription)
2.6 Operator session confidentiality, integrity.	X	X	Limited to virtualisation infrastructure/environment and dedicated operator PCs
2.7 Vulnerability scanning	X	X	On the virtualisation infrastructure/environment
2.8 Outsourced critical activity protection	X		To be considered by user depending on outsourced model (HSM) – VPN is managed by Swift Potential access to data to be covered in contract (if possible through virtualised environment)
2.9 Transaction business controls	X		
2.10 Application hardening	X		
2.11A RMA business controls	X		

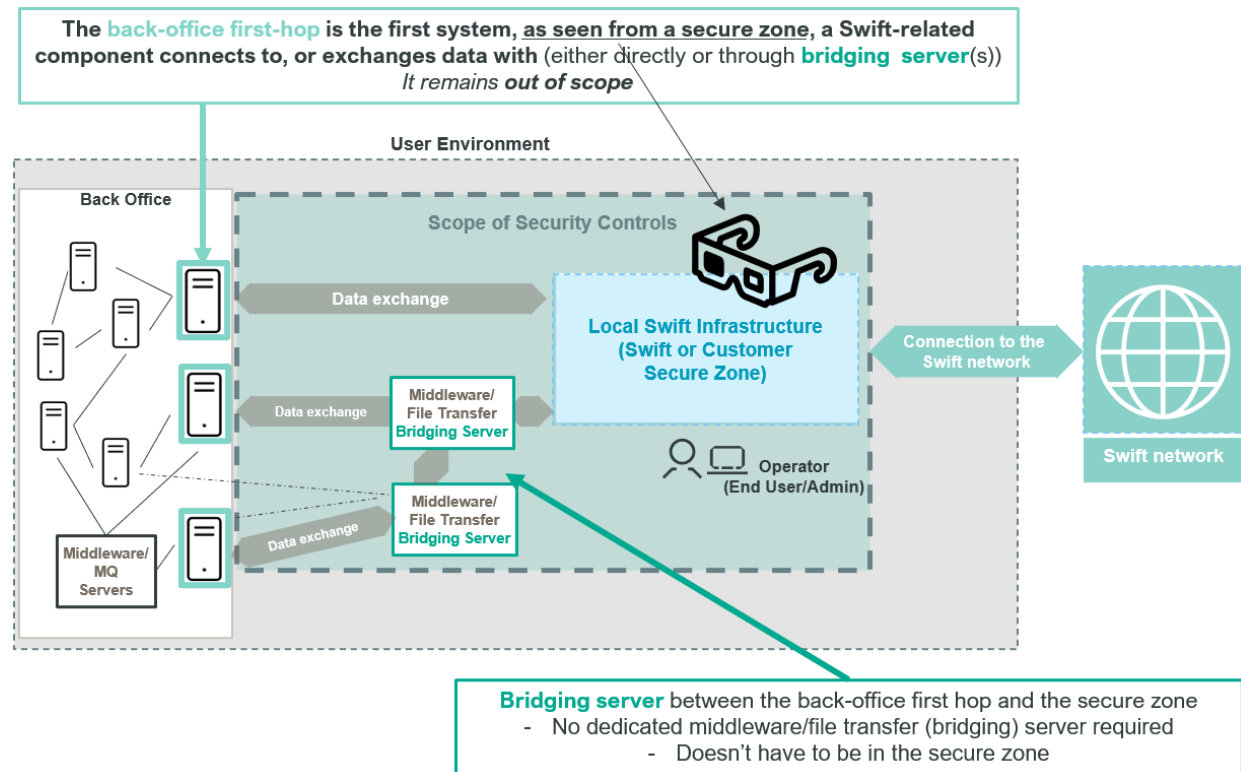
Virtualisation infrastructure/environment includes Network/FW devices

Control	User	CP	Relevance for the Cloud Provider (CP)
3.1 Physical security	X	X	Of the virtualisation infrastructure/environment.
4.1 Password policy	X	X	On the virtualisation infrastructure/environment and the subscription set up for the user
4.2 Multi-factor authentication.	X	X	Support secure access to the virtualisation infrastructure/environment set up for the user
5.1 Logical access control	X	X	On the virtualisation infrastructure/environment and the subscription set up for the user
5.2 Token management.	X	X	Solution dependent (HSM or others used by CP to access the virtualised infrastructure)
5.3A Personnel vetting process	X	X	For operators of the virtualisation infrastructure/environment and subscription set up for the user
5.4 Password repository protection	X	X	For the virtualisation infrastructure/environment, subscription and solution dependent (HSM or ?)
6.1 Malware protection.	X	X	Solution dependent on the virtualisation infrastructure/environment and operator PCs
6.2 Software integrity	X		
6.3 Database integrity	X		
6.4 Logging and monitoring	X	X	On the virtualisation infrastructure/environment and the subscription set up for the user
6.5A Intrusion detection	X	X	On the virtualisation infrastructure/environment and the subscription set up for the user (RACI)
7.1 Cyber incident response planning.	X	X	To be incorporated in customer incident response plan
7.2 Security training and awareness.	X	X	For operators of the virtualisation infrastructure/environment and subscription set up for the user
7.3A Penetration testing	X	X	On the virtualisation infrastructure/environment supporting the subscription set up for the user.
7.4A Scenario risk assessment	X	X	On the virtualisation infrastructure/environment supporting the subscription set up for the user.

Virtualisation infrastructure/environment includes Network/FW devices

Appendix H: Back-Office First Hop Flows Protection

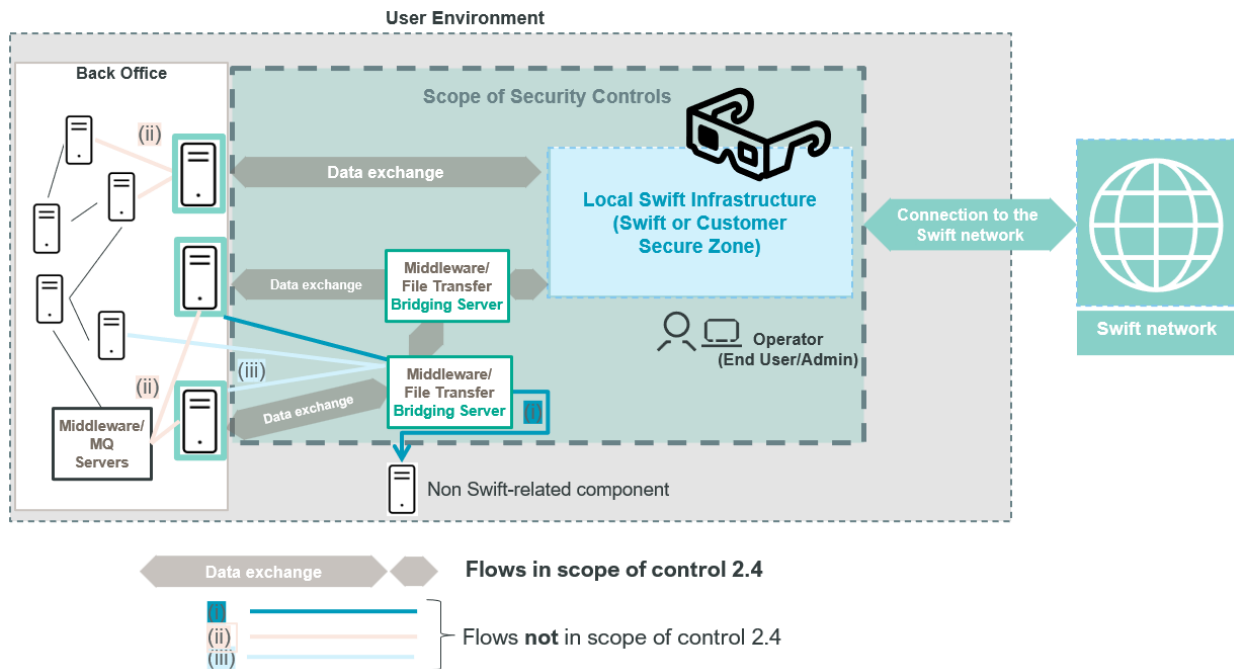
The purpose of the drawings below is to visualise and support the journey to mandatory for the control 2.4 to secure the data exchange with the back-office first hop as seen from the secure zone.



Drawing 15a: The back-office first hops and servers bridging them with the secure zone

The drawing above depicts back-office first hops that are the first systems as seen from a secure zone component. As such, when not co-hosted with a Swift-related in-scope component (component in the user's Swift infrastructure) and not in the secure zone, these back-office systems remain out of scope.

Reminder: servers bridging a back-office first hop with the secure zone do not have to be in the secure zone, neither do they have to be dedicated to such bridging.

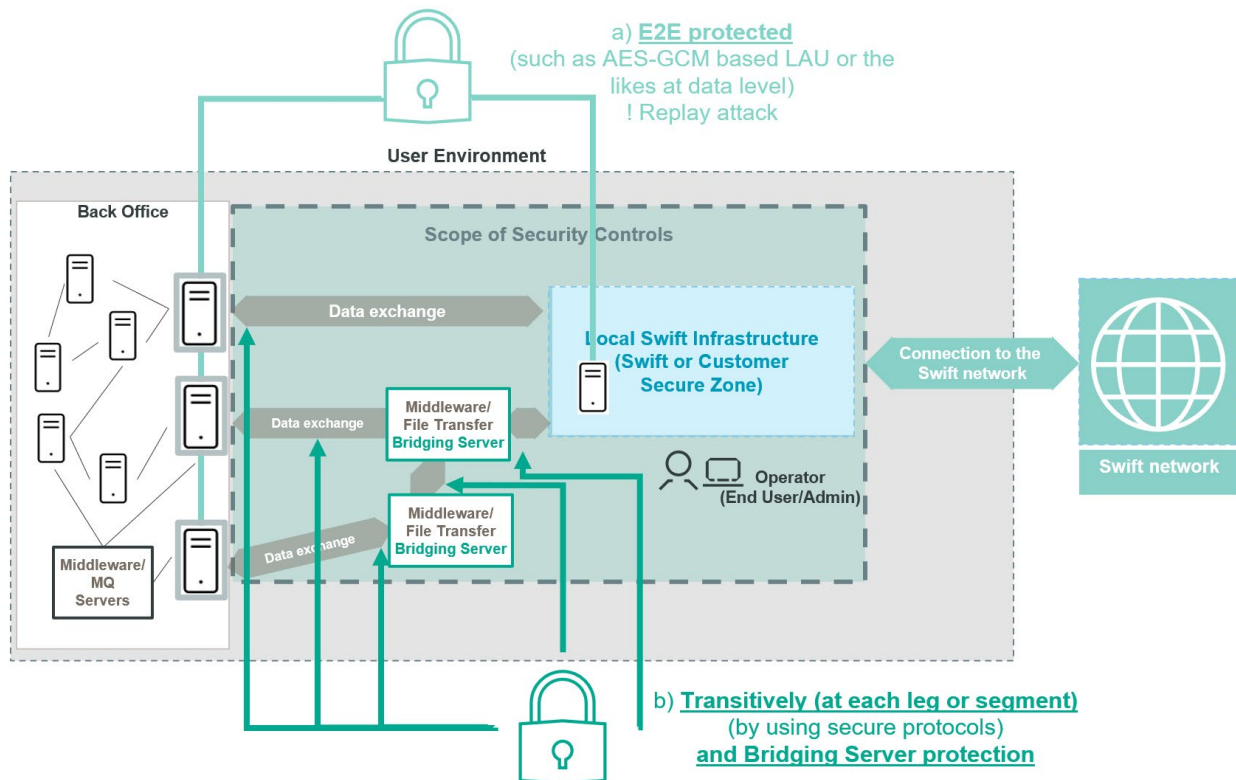


Drawing 15b: Flows in scope of control 2.4

The data exchange between a secure zone component (first element) and the back-office first hop (second element) can be:

- directly performed between those two elements (point to point connection), or
- through a single server (such as a middleware/file transfer server) bridging those two elements, or
- through a series of servers (such as middleware/file transfer servers) bridging those two elements.

However, as illustrated above and considering a bridging server does not need to be dedicated to the sole Swift-related flows, the flows towards (i) a non Swift-related component and (ii) between the back-office first hop(s) and other back-office system are out of scope of control 2.4 (even if (iii) those flows go through a bridging server that is facilitating the data exchange with the secure zone).



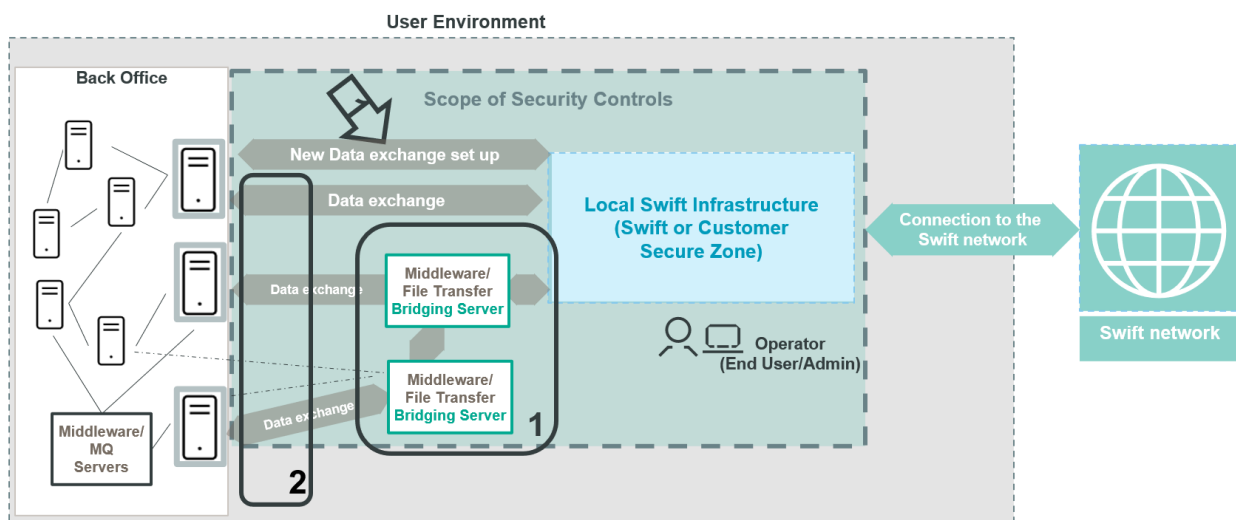
Drawing 16: Alternative ways of protecting the data exchange between the secure zone and the back-office first hops

The protection of the data exchange can be done

- end-to-end at data level, or
- through secure protocols on each segment, between the bridging servers, and by protecting the bridging servers themselves. In such case, the bridging servers are the guardian of the data exchange.

When an end-to-end protection exists at data level, combined with replay attack prevention, the protection of the in-between bridging servers is of less importance. Indeed, the data, individually authenticated and protected by the back office, that is validated by a component in the secure zone, cannot be modified during the data exchange. In this case, the bridging servers are not the guardian of the data exchange.

Different methods can be used for the various data exchange or flows. Therefore, we strongly recommend supporting the journey by identifying the flows that fall in scope and by assessing their security posture. Then, appropriate actions should be taken to achieve the two phases depicted below.



Drawing 17: The two phases**Phase 1 (as from CSCF v2026 that turns the control 2.4 as mandatory) - Protect the new direct (point to point) flows and the bridging servers that are guardian of the data exchange**

- For the flows that rely, for the security of the exchanged data, on bridging servers (such as middleware or file transfer servers) because there is no end-to-end protection of the data:
 - o Protect those bridging servers, mandatory in-scope components of the various controls, that are not as Advisory in-scope anymore
 - o Secure the data exchange between those bridging servers and the components in the secure zone
- When introducing new direct flows, such as a new type of data exchange between a new back-office first hop and a secure zone component, then protect, through security by design, the data exchange in line with control 2.4, such as by using i) end-to-end data protection or ii) a (native) secure protocol between the two elements.

Phase 2 (in a subsequent CSCF version, targeting possibly v2028) - Protect the legacy flows

- For the flows that rely, for the security of the exchanged data, on bridging servers (such as middleware or file transfer servers):
 - o Secure the data exchange between those bridging servers and the back-office first hop (legacy flows)
- Secure the remaining direct data exchange between the secure zone components and the back-office first hops (legacy flows).

To prepare for the various phases, we recommend supporting the prioritisation of those various flows through a risk-based assessment.

Legal Notices

Copyright

Swift © 2025. All rights reserved.

Confidentiality

This publication contains Swift or third party confidential information. Do not disclose this publication outside your organisation without Swift's prior written consent. You may however share this publication on a need-to-know basis with third parties that support you in connection with the Swift Customer Security Programme initiatives provided (i) you inform the recipient of the confidential nature of the information and (ii) you ensure that it is bound by no less stringent obligations of confidentiality.

Disclaimer

The information in this publication may change from time to time. You must always refer to the latest available version.

Translations

The English version of Swift documentation is the only official and binding version.

Trademarks

Swift is the trade name of S.W.I.F.T. SC. The following are registered trademarks of Swift: 3SKey, Innotribe, MyStandards, Sibos, Swift, SwiftNet, Swift Institute, the Standards Forum logo, the Swift logo, Swift GPI with logo, the Swift GPI logo, and UETR. Other product, service, or company names in this publication are trade names, trademarks, or registered trademarks of their respective owners.